2.2.1 Identify AI System Risks

Scenario

In this lab, you'll learn how to identify and describe potential security threats in AI systems before they cause harm. You'll explore how threat modeling provides a structured way to think about risks-what could go wrong, why it might happen, and how to reduce the chance of it happening again.

You'll begin with open-ended discovery to identify risks in autonomous or semi-autonomous AI systems. Then, you'll apply a modern threat-modeling framework tailored for AI agents to structure those risks into clear, repeatable scenarios.

Your Mission:

- Identify potential threats in AI systems that operate independently.
- Learn how threat modeling organizes risks into patterns and scenarios.
- Compare freeform discovery against a standardized threat-model format.
- Use MAESTRO Framework for Threat Modeling

Exam Objectives

This activity is designed to test your understanding of and ability to apply content examples in the following CompTIA SecAI+ objectives:

- 2.1 Given a scenario, use AI threat-modeling resources.

Identify AI System Risks

Before you start building a formal threat model, it helps to understand how an AI system can fail at different levels.

- CSA's MAESTRO framework breaks the layers down
- from the core model that generates responses to the wider ecosystem where multiple agents interact.

In this exercise, you'll move through each of the seven layers, using the model to explore how problems might appear at that level.

Step 1: Open the Open WebUI application.

Step 2: Start a new chat with gemini2.5 flash, enter the following prompt, and note the response:

Prompt 1:

```
What kinds of issues could come from flaws or
limitations in the base AI model itself?
```

Insights: The Foundation Models layer is where intelligence begins. Here, hidden bias, poisoned training data, unsafe updates, or proprietary model leaks can ripple upward into every other layer.

Step 3: In the same chat, enter the following prompt and note the response:

Prompt 2:

```
An AI agent can call tools, APIs, or scripts on its
own.  What kinds of misuse or manipulation might
happen through those connections?
```

Insights: The Agent Frameworks layer defines how intent turns into action. Prompt injections, plugin abuse, and dependency hijacking are all common threats here.

Step 4: In the same chat, enter the following prompt and note the response:

Prompt 3:

```
What could go wrong with the environment the agent
runs in - its servers, containers, or network setup?
```

Step 5: In the same chat, enter the following prompt and note the response:

Prompt 4:

```
If the AI started acting unpredictably, what
monitoring or feedback failures could allow that to
go unnoticed?
```

Insights: Layer 5 is Evaluation and Observability. Without visibility - logs, metrics, or audits - bad behavior can persist indefinitely. MAESTRO stresses that you can't secure what you can't observe.

Step 6: In the same chat, enter the following prompt and note the response:

Prompt 5:

```
How could weak policies or missing compliance
controls make an otherwise secure AI system risky for
the organization?
```

Insights: Even well-built systems can fail compliance or data-protection rules. The Security and Compliance layer ensures technical security translates into organizational safety.

Step 7: In the same chat, enter the following prompt and note the response:

Prompt6:

```
When multiple AI agents share a workspace or
marketplace, what kinds of conflicts or manipulations
could arise?
```

Insights: The Agent Ecosystem is the outermost layer - the social space of agents. Collusion, misinformation loops, and untrusted integrations all live here.

When you look back over the seven layers of MAESTRO, you should see how each one stacks on the next:

- Foundation Models define how an AI system thinks.
- Data Operations control what it knows.
- Agent Frameworks shape how it acts.
- Deployment & Infrastructure decide where it runs.
- Evaluation & Observability show how we measure and correct it.
- Security & Compliance determine who is responsible.
- Agent Ecosystem governs how it behaves among others.

Together, these layers form a map of AI-specific risk - one that goes beyond servers, networks, and users to include reasoning, autonomy, and collaboration between agents. Traditional frameworks like STRIDE or MITRE ATT&CK don't yet fully capture these new surfaces; MAESTRO helps fill that gap by mapping emergent and agentic threats through a structure security teams already understand.

MAESTRO is developed by the Cloud Security Alliance (CSA), which publishes ongoing updates and applied examples. You can read more about it at https://cloudsecurityalliance.org.

2.2.2 Apply a Threat Modeling Framework to AI

Applying a threat modeling framework to AI systems means identifying how data, tools, and model behavior could be misused or manipulated, not just how software might be exploited. This shifts the focus from traditional vulnerabilities to risks like overexposure of data, misuse of tool access, and untrusted or attacker-controlled inputs influencing AI decisions.

Step 1: In the same OpenWebUI chat, enter the following prompt and note the response:

Prompt 1:

```
You are a security analyst reviewing an AI content-
moderation system. List all the ways this system
could fail or be misused. Include both accidental
errors and intentional manipulations.
```

Insights: Unstructured prompting lets the model think freely-but the results often overlap, skip entire domains (like infrastructure or observability), or mix system flaws with user behavior.

Step 2: In the same chat, enter the following prompt and note the response:

Prompt 2:

```
Re-evaluate the same AI content-moderation system
using the following framework:

For each layer below, identify:

- One top threat

- A short example scenario (≤25 words)

- Impact (H/M/L)

- Likelihood (H/M/L)

- One key mitigation

Layers:

1. Foundation Models
```

```
2. Data Operations
3. Agent Frameworks
4. Deployment & Infrastructure
5. Evaluation & Observability
6. Security & Compliance
7. Agent Ecosystem

Return results as a concise Markdown table.
```

Insights: By introducing a framework, the same model now must think systematically. Instead of random risks, you get coverage across data, tooling, infrastructure, and governance-each tied to specific mitigations.

Step 3: In the same chat, enter the following prompt and note the response:

Prompt 3:

```
Do any of these threats share a common cause across
multiple layers?
```

Insights: One effective way to prioritize threats is through consolidation - if a single underlying issue contributes to multiple threats across different layers, address that issue first.

Q.1: Which causes were identified as affecting multiple layers of the threat model? (Select all that apply)

A) Lack of user engagement
B) Lack of version control
C) Lack of robust security
D) Lack of logging and monitoring

1. In the same chat, enter the following prompt and note the response:

```
Which of the threats could occur without malicious
intent? Which threats require an adversary?
```

Insights: Not all AI threats come from attackers. Some are emergent risks-failures caused by the model's own behavior or design-while others are adversarial, triggered by deliberate manipulation. Distinguishing the two helps analysts choose the right defenses: emergent risks need better design and monitoring, while adversarial ones require stronger controls and validation.

Q.2: Which of the following from the threat model requires an adversary?

A) Data Poisoning
B) Overfitting
C) Bias in training data
D) Lack of real-time monitoring

You've successfully applied threat modeling techniques to AI.

2.2.3 Threat Modeling through MAESTRO Framework

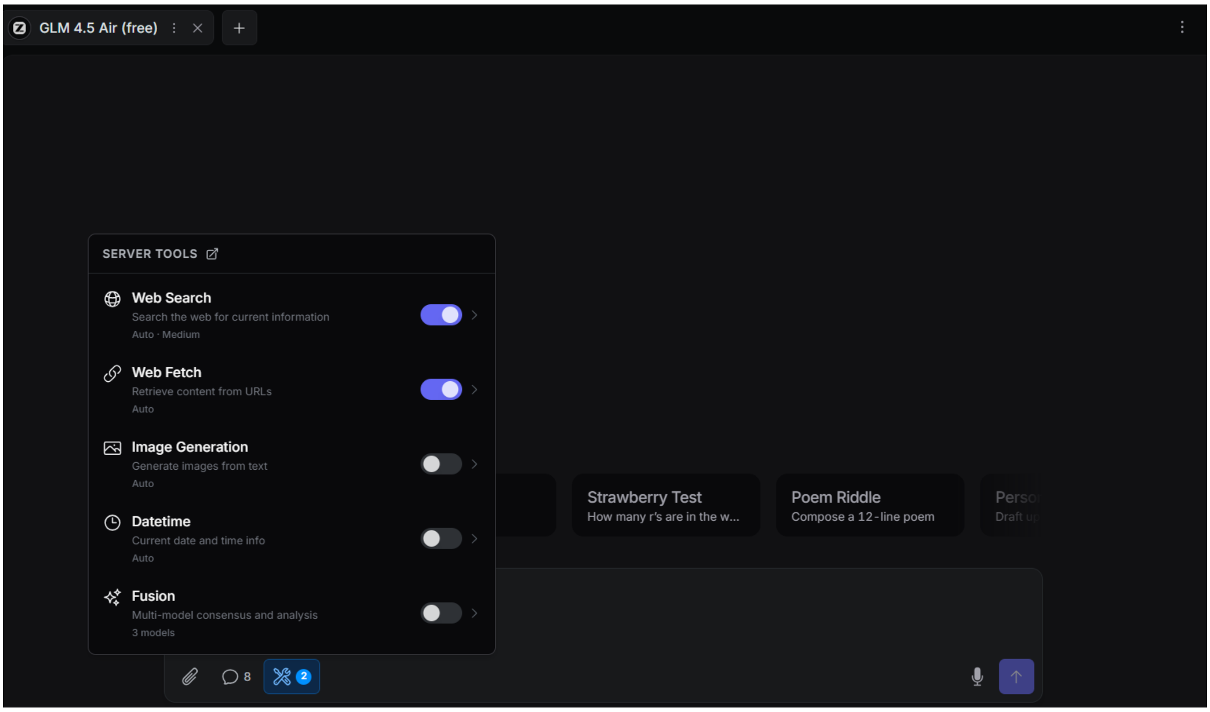
So far, you've explored threat modeling concepts and applied structured prompts directly through an LLM. Those steps built the foundation - helping you see how a model can reason through AI system risks using the MAESTRO framework.

We will use web search here, so perform this lab in OpenRouter

Step 1: In a new chat with an LLM in OpenRouter, enter the following prompt and note the response (Ensure Web Search and Web fetch is turned ON):

Prompt 1:

```
Use the MAESTRO framework from
https://cloudsecurityalliance.org to model threats
for a content moderation system.
```

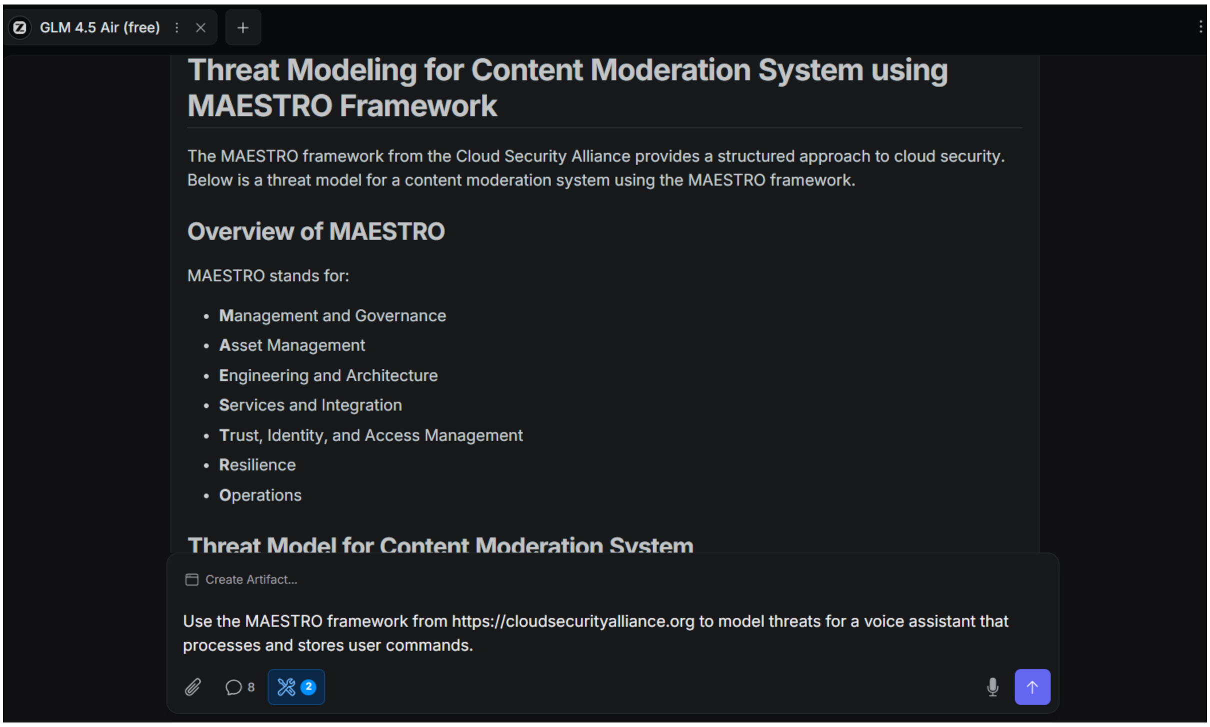


Insights: The MAESTRO framework structures AI risks across seven layers, linking technical flaws to broader ecosystem effects.

Step 2: Now, enter the following prompt, and note the response:

Prompt 2:

```
Use the MAESTRO framework from
https://cloudsecurityalliance.org to model threats
for a voice assistant that processes and stores user
commands.
```



Q.1 Which MAESTRO layer most directly addresses the risk of a voice assistant storing user commands without adequate encryption?

A) Data Operations
B) Agent Frameworks
C) Security & Compliance
D) Foundation Models

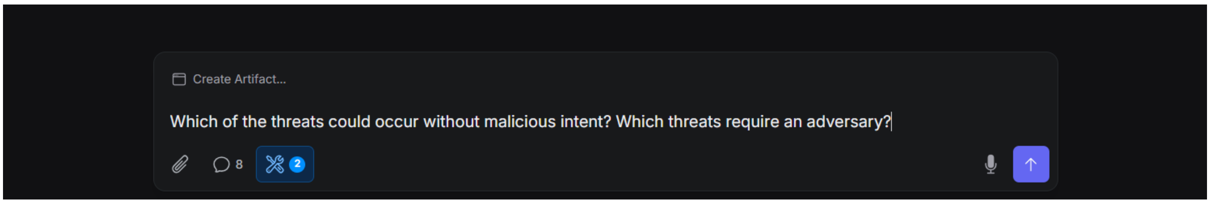
Q.2 Based on the MAESTRO output, which mitigation would best reduce multiple listed threats at once?

A) Regular model retraining
B) Encryption and strict access control
C) User-education campaigns
D) Expanding hardware capacity

Step 3: In the same chat, enter the following prompt and note the response:

Prompt 3:

Which of the threats could occur without malicious intent? Which threats require an adversary?



You've successfully used LLMs to model threats!!